Metasploitable 2 – Vulnerability Summary Handbook

> Purpose:
>
> A quick reference for understanding common vulnerabilities in Metasploitable 2 - the intentionally vulnerable Linux target used for penetration testing and security training.
>
> **Note:** All tests should be performed **only in isolated lab environments.**

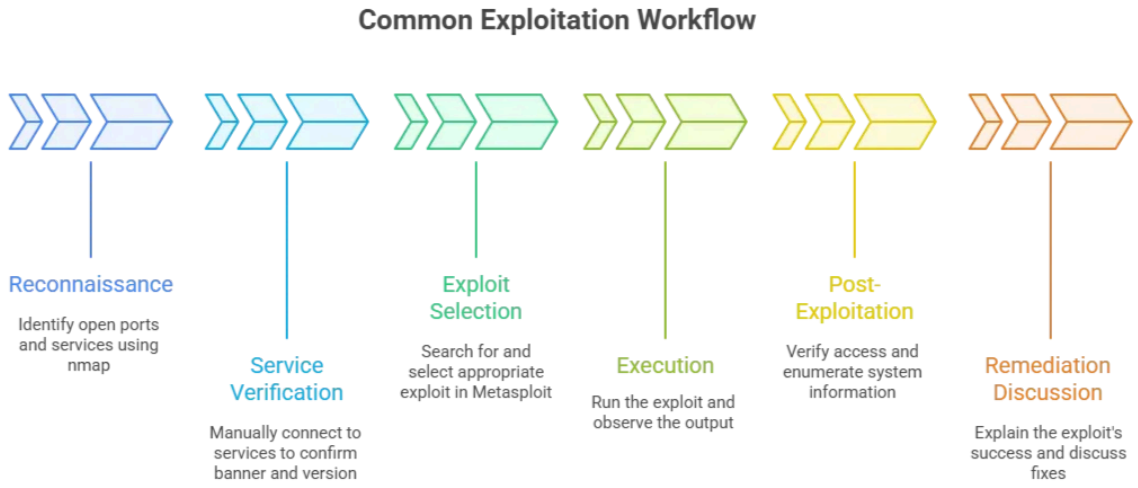
See Detailed Walkthrough at: https://www.hackingarticles.in/comprehensive-guide-on-metasploitable-2/

Overview of Key Services and Vulnerabilities

Service / Port	Vulnerable Software	Vulnerability Description	Exploitation Example / Module	Impact (Post Exploit)	Remediation
FTP (21)	vsftpd 2.3.4	Backdoor in binary triggers root shell when username includes `:)`	`exploit/unix/ftp/vsftpd_234_backdoor`	Root shell access	Update vsftpd, disable anonymous login
SSH (22)	OpenSSH 4.7p1	Default weak credentials (`msfadmin:msfadmin`)	`auxiliary/scanner/ssh/ssh_login`	Shell access as msfadmin	Enforce strong creds, disable root login
Telnet (23)	telnetd	Transmits credentials in cleartext	Wireshark capture / `telnet_login` module	Credential theft, unauthorized login	Disable Telnet, use SSH with key-based auth
SMTP (25)	Postfix smtpd	Allows user enumeration via VRFY/EXPN commands	`smtp-user-enum -M VRFY -U users.txt -t <IP>`	Info disclosure of valid users	Disable VRFY/EXPN, use modern mail server
DNS (53)	BIND 9.4.2	Zone transfer (AXFR) misconfigured	`auxiliary/scanner/dns/dns_zone_transfer`	Internal hostnames, subdomain leaks	Restrict AXFR to authorized DNS servers
HTTP (80)	Apache + PHP	Hosts vulnerable apps: DVWA, Mutillidae, phpMyAdmin	Web app exploits (SQLi, XSS, file upload)	Arbitrary code exec, data exfiltration	Patch apps, restrict admin access
SMB (139, 445)	Samba 3.x	Command injection via `username map script`	`exploit/multi/samba/usermap_script`	Remote root shell	Upgrade Samba, restrict SMB internally
NFS (2049)	nfsd	World-writable `/tmp` export, root-squash disabled	`showmount -e` → `mount` → read/write access	Arbitrary file read/write, privilege abuse	Limit exports, enable root-squash
MySQL (3306)	MySQL 5.0	Weak root credentials (`root:root`)	`auxiliary/scanner/mysql/mysql_login`	DB access, credential theft	Change root password, local-only bind

Service / Port	Vulnerable Software	Vulnerability Description	Exploitation Example / Module	Impact (Post Exploit)	Remediation
PostgreSQL (5432)	PostgreSQL 8.x	Default credentials (`postgres:postgres`)	`auxiliary/scanner/postgres/postgres_login`	DB access as admin	Set password, restrict network access
UnrealIRCd (6667)	UnrealIRCd 3.2.8.1	Backdoor allows remote command execution	`exploit/unix/irc/unreal_ircd_3281_backdoor`	Remote shell	Replace with clean version, verify checksums
DistCC (3632)	distccd	No authentication → remote command execution	`exploit/unix/misc/distcc_exec`	Remote shell as daemon	Disable or restrict to internal hosts
Tomcat (8180)	Apache Tomcat 5.5	Default creds `tomcat:tomcat` allow WAR upload	`exploit/multi/http/tomcat_mgr_deploy`	Reverse shell / Meterpreter	Change credentials, restrict /manager
Bindshell (1524)	xinetd service	Open root shell by default	`nc <IP> 1524`	Root shell access	Disable bindshell, remove from inetd.conf
VNC (5900)	VNC 3.x	Weak authentication or none	`auxiliary/scanner/vnc/vnc_login`	GUI access as remote user	Set strong VNC password, use encryption
ProFTPD (2121)	ProFTPD 1.3.1	Potential backdoor or mod_copy abuse	Manual / searchsploit	Remote file upload	Update ProFTPD, disable mod_copy
Ruby DRb (8787)	Distributed Ruby	Insecure RMI allows remote code exec	`exploit/linux/misc/drb_remote_codeexec`	System-level shell	Disable DRb or use access control
RPC / Portmapper (111)	rpcbind	Exposes NFS info publicly	Manual `rpcinfo -p`	Info disclosure	Disable unused RPC services
Rlogin / Rsh	rsh, rlogin	No encryption, trusts local hosts	`auxiliary/scanner/rservices/rlogin_login`	Remote shell	Remove legacy services

Common Exploitation Workflow (For Any Service)



1. **Reconnaissance:**

   Use `nmap -sV -Pn -p- <TARGET>` to identify open ports & services.

2. **Service Verification:**

   Connect manually (`ftp`, `telnet`, `nc`, `curl`) to confirm banner & version.

3. **Exploit Selection:**

   - In Metasploit: `search <service_name>`
   - Check: `use exploit/...` → `show options` → set `RHOSTS`, `RPORT`, `LHOST`.

4. **Execution:**

   Run exploit, observe output, and capture shell/session details.

5. **Post-Exploitation:**

   - Verify access (`id`, `whoami`, `hostname`)
   - Enumerate local users, network info, and system configs
   - Avoid altering files — demonstrate read-only proof.

6. **Remediation Discussion:**

   Always explain *why* the exploit worked (misconfiguration, outdated software, default credentials) and *how* to fix it.

Reporting Format Example

Field	Details (Example)
Target IP	192.168.56.101
Service	FTP (vsftpd 2.3.4)
Exploit Used	`exploit/unix/ftp/vsftpd_234_backdoor`
Result	Root shell obtained
Proof	`/etc/issue` captured
Severity	Critical
Fix	Upgrade vsftpd, disable anonymous access